

Excellent. You're building this the right way. From this point onward, I'll write it at the level expected of a **Senior SAP Security/GRC Architect (10–15+ years)**. This is the level of questioning you can expect from IBM, Deloitte, Accenture, EY, Capgemini, SAP, Saudi Aramco, SABIC, Lucid Motors, NEOM, and major manufacturing clients.

CATEGORY 2 – SAP SECURITY FUNDAMENTALS (PART 3)

Chapter 3 – Advanced Authorization Concepts

Q21. Explain SAP_ALL and SAP_NEW. What is the difference?

Interviewer's Objective

This is one of the most common questions asked to determine whether you understand SAP authorization concepts beyond basic administration.

Executive Answer

Both SAP_ALL and SAP_NEW are SAP standard authorization profiles, but they serve completely different purposes.

SAP_ALL

SAP_ALL grants almost unrestricted access to the SAP system.

It contains nearly every authorization object with unrestricted values.

A user assigned SAP_ALL can:

- Execute almost every transaction
- Maintain configuration
- Create users
- Modify roles
- Debug programs
- Maintain tables
- Transport changes

SAP_ALL should never be assigned permanently to business users.

Typical use cases:

- Emergency troubleshooting
- Initial system setup
- Temporary administrator access
- Sandbox systems

SAP_NEW

SAP_NEW is completely different.

It is designed to provide temporary access to new authorization checks introduced after upgrades.

Example:

ECC Enhancement Pack

↓

S/4HANA Upgrade

↓

SAP introduces new authorization objects

↓

SAP_NEW temporarily grants those missing checks.

Its purpose is to avoid business disruption immediately after upgrades.

Key Differences

SAP_ALL

Full system access

Administrative profile

Used sparingly

Security risk if misused

SAP_NEW

Temporary upgrade support

Compatibility profile

Used during upgrades

Helps avoid authorization failures

Best Practice

Never leave SAP_NEW assigned permanently after an upgrade.

Once role redesign is complete and authorization objects are incorporated into business roles, SAP_NEW should be removed.

Q22. What happens internally when SAP performs an authorization check?

Executive Answer

SAP follows a structured authorization evaluation process.

Step 1

The application requests an authorization check using the ABAP statement:

```
<> ABAP  
  
AUTHORITY-CHECK OBJECT 'F_BKPF_BUK'
```



Step 2

SAP reads the authorization object.

Step 3

The system checks the authorization fields.

Example:

```
Company Code  
  
Activity  
  
Document Type
```



Step 4

SAP compares the required values against the user's generated authorization profile.

Step 5

If every required field matches,

↓

Access Granted

Otherwise,

↓

Authorization Failure

↓

SY-SUBRC = 4

Interview Tip

Senior interviewers appreciate candidates who understand that authorization checks are implemented by developers using the `AUTHORITY-CHECK` statement, not magically performed by SAP.

Q23. Explain S_TABU_DIS and S_TABU_NAM.

One of the most frequently asked questions for experienced consultants.

S_TABU_DIS

Controls table maintenance based on Authorization Groups.

SAP checks:

Authorization Group



Activity

Authorization Groups are maintained using transaction:



S_TABU_NAM

Introduced to provide more granular table authorization.

Instead of Authorization Groups,

it checks the actual table name.

Example

USR02

AGR_USERS

T000



Difference

S_TABU_DIS

Authorization Group

Coarse control

Older approach

S_TABU_NAM

Table Name

Fine-grained control

Preferred for sensitive tables

Best Practice

For highly sensitive tables such as user master, role assignments, or security configuration, S_TABU_NAM provides stronger control and better auditability.

Q24. How would you secure sensitive SAP tables?

Executive Answer

Sensitive tables should never rely solely on transaction-level restrictions.

A layered approach includes:

Layer 1

Restrict transactions:

- SE16
- SE16N
- SM30
- SM31

Layer 2

Control table access using:

S_TABU_DIS



S_TABU_NAM

Layer 3

Restrict debugging.

Layer 4

Restrict transport access.

Layer 5

Enable audit logging.

Example Sensitive Tables

Table	Purpose
USR02	User Master
USR04	User Profiles
AGR_USERS	Role Assignment

Table	Purpose
AGR_DEFINE	Roles
T000	Clients
RFCDES	RFC Destinations
USOBT_C	SU24
USOBX_C	SU24 Check Indicators

Q25. Explain Debug Authorization.

Executive Answer

Debugging allows users to bypass normal business logic.

If not controlled,

users may:

- Modify variables
- Skip validations
- Change data
- Execute unauthorized functions

Therefore,

debug authorization is extremely sensitive.

Important Authorization Objects

S_DEVELOP



S_DEBUG

Best Practice

Only ABAP developers and a limited number of administrators should receive debugging access.

Production debugging should require formal approval and be closely monitored.

Q26. Explain Background Job Security.

Executive Answer

Background jobs execute under the authorization of the scheduling user.

Therefore,

the job inherits that user's authorizations.

Security Risks

- Excessive privileges
 - Shared IDs
 - Unrestricted RFC access
 - Sensitive data extraction
-

Best Practices

- ✓ Dedicated Batch Users
 - ✓ Least Privilege
 - ✓ Secure Variants
 - ✓ Job Monitoring
 - ✓ Periodic Review
-

Important Transactions



Q27. Explain Authorization Groups.

Authorization Groups simplify administration by grouping related objects.

Examples

Tables

Programs

Spool

Documents

Instead of protecting hundreds of objects individually,
one authorization group controls them.

Example

Finance Tables

↓

Authorization Group

FI01



All finance tables inherit the same authorization policy.

Q28. Explain User Master Record.

The User Master Record contains

- User ID
- Password

- User Type
- Roles
- Profiles
- Parameters
- Groups
- Validity Dates
- License Type

Transaction

SU01



Important Tabs

Address

Logon Data

Defaults

Parameters

Roles

Profiles

Groups

Q29. What happens when a role is changed?

This question is commonly asked by senior architects.

Step 1

Role Modified



PFCG

Step 2

Authorization Generated



Profile Updated

Step 3

Transport



QA



Production

Step 4

User Comparison

Step 5

User Buffer Refresh

Only after these steps does the new authorization become fully effective.

Q30. Explain Transport Strategy for Security Roles.

Executive Answer

A mature SAP landscape follows a controlled transport strategy.

Typical flow:

Development



↓

Quality

↓

Pre-Production

↓

Production

Objects Transported

Roles

Profiles

SU24 Changes

Authorization Objects

Custom Transactions

Best Practices

- Separate development and production duties.
 - Test roles in QA before production.
 - Include security validation in SIT and UAT.
 - Reconcile role changes after transport.
 - Maintain transport documentation for audit purposes.
-

Q31. What are the most important SAP Security tables?

Senior interviewers often ask this as a rapid-fire question.

Table	Description
AGR_DEFINE	Role Header
AGR_USERS	User-to-Role Assignment

Table	Description
AGR_1251	Authorization Data
AGR_1252	Organizational Values
AGR_AGRS	Composite Role Assignments
USR02	Logon Data
USR04	User Profiles
USR21	User Address Link
UST04	User Profiles
USOBT_C	SU24 Authorization Proposals
USOBX_C	SU24 Check Indicators
TOBJ	Authorization Objects
TSTC	Transaction Codes
TSTCT	Transaction Descriptions
RFCDES	RFC Destinations

Real-World Scenario

Interviewer

"An auditor reports that a user accessed a sensitive table through SE16N. How would you investigate and prevent recurrence?"

Executive Answer

My investigation would follow a structured approach:

1. Confirm which table was accessed and identify its sensitivity.
2. Review the user's assigned roles in SU01 and PFCG.
3. Analyze authorization objects, particularly S_TABU_DIS and S_TABU_NAM, to determine why access was permitted.
4. Check whether debugging or other elevated privileges contributed to the access.

5. Review audit logs and STAUTHTRACE, if available, to understand the execution path.
6. Identify whether the access was legitimate, accidental, or unauthorized.
7. If excessive access exists, redesign the role based on least privilege, transport the changes through the landscape, and document the remediation for audit purposes.
8. Recommend periodic reviews of table access and additional monitoring for high-risk tables.

This approach demonstrates technical competence, governance awareness, and audit readiness.

Architect's Perspective

A senior SAP Security consultant doesn't merely answer "which transaction" or "which table." They explain **why** a control exists, **how** it supports compliance, **what** the business impact is, and **how** they would implement or improve it in a real project. That's the mindset interviewers look for at Lead and Architect levels.

Category 2 Progress

At this point, we've covered:

-  SAP Security Architecture
-  Authorization Concepts
-  PFCG
-  SU24
-  SU53
-  STAUTHTRACE
-  User Types
-  RBAC
-  Organizational Levels
-  SAP_ALL vs. SAP_NEW
-  Table Security
-  Background Job Security
-  RFC Security
-  Transport Strategy
-  Security Tables
-  Advanced troubleshooting scenarios

This forms a solid foundation before moving into **Category 3 – SAP Role Design & Enterprise RBAC**, where we'll go beyond administration and focus on designing scalable,

auditable authorization models for global S/4HANA landscapes. This is one of the most important topics for senior SAP Security and GRC interviews.